



Core Concepts: Account Data, PAN, CHD vs SAD, and the CDE

UNDERSTANDING KEY TERMINOLOGY AND DATA CLASSIFICATIONS IN
PAYMENT SECURITY COMPLIANCE





Importance of Payment Card Data Security

Every transaction involves complex data exchanges.

- Beneath simplicity, security is essential for protection.

The payment card industry faces continual threats.

- Both cybercriminals and internal mishandling pose risks.

Mishandling account data can cause major harm.

- Risks include financial loss, penalties, and lost trust.

Understanding data and boundaries is crucial for organizations.

- These decisions impact compliance and customer confidence.

Key Categories of Payment Card Data

Account data enables a payment card transaction.

- Includes all information tied to a payment card.

Two foundational categories: CHD and SAD.

- Cardholder Data (CHD) and Sensitive Authentication Data (SAD).

These categories guide security and compliance decisions.

- Classifications shape handling and storage requirements.

Differentiating CHD and SAD is fundamental.

- Impacts operational and regulatory approaches.



Elements of Cardholder Data (CHD)

PAN is the most critical cardholder data element.

- It uniquely identifies the cardholder's account.

Cardholder's name, expiration date, and service code are included.

- Each appears during typical online checkouts.

CHD security is mandatory for organizations.

- Security of elements is non-negotiable.

Combined CHD elements facilitate legal transactions.

- PAN with other data enables payments.



Sensitive Authentication Data (SAD) Overview

SAD includes magnetic stripe or chip contents.

- Full data on these components is protected information.

SAD covers CVV/CVC and PIN codes.

- These are used for transaction authentication.

SAD storage is forbidden after authorization.

- Security standards prohibit post-authorization storage.

Breaches involving SAD lead to rapid fraud.

- SAD exposure unlocks potential for fraudulent use.





Rules for Storing CHD vs. SAD

CHD storage allowed with strict security controls.

- Encryption and controls enable limited ongoing storage.

Storing SAD on servers is strictly prohibited.

- Even temporary SAD storage is against security standards.

Classification determines storage permissions.

- Acceptable storage depends on data type (CHD or SAD).

Strict boundaries protect against catastrophic breaches.

- These rules serve as critical protective measures.

Risks From Improper CHD and SAD Handling

Identify storage, processing, and transmission points for CHD.

- Locating data movement helps minimize risks.

Writing down customer SAD creates compliance failures.

- Even well-meant actions increase security vulnerabilities.

Employee habits can undermine security controls.

- Uninformed practices put organizations at risk.

Reflection is needed on real-world storage practices.

- Identify areas for improvement in your environment.



Classifying Example Card Data Elements

PAN, cardholder name, expiration date are CHD.

- These may be stored with applicable controls.

CVV and magnetic stripe data are SAD.

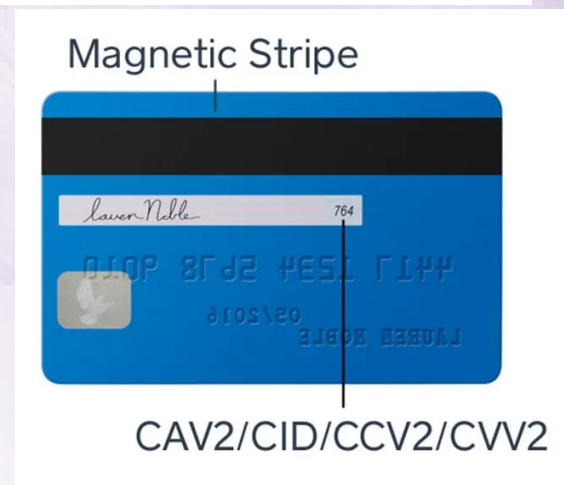
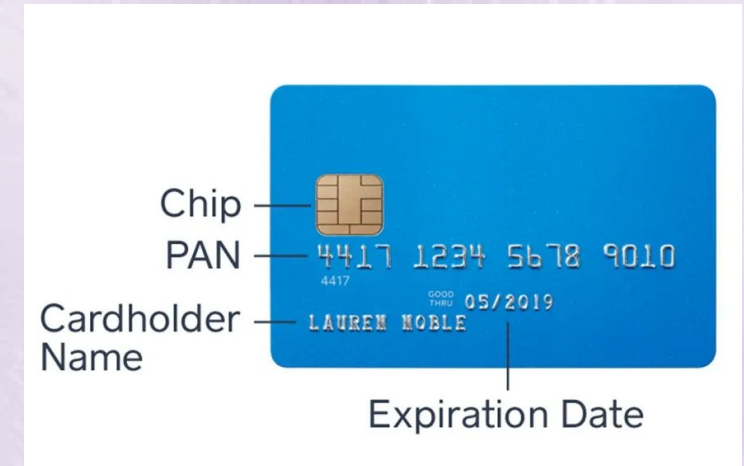
- Post-authorization storage of SAD is forbidden.

Prohibition applies to all SAD, including logs and dumps.

- Even temporary or hidden SAD storage is not allowed.

Breaches often result from stored SAD in backups.

- Accidental retention has led to major compromises.



Encryption: The Cornerstone of Cardholder Data Protection

Encryption is essential for storing PAN securely.

- Strong cryptographic methods must be used for unreadability.

Physical or personnel controls are not sufficient safeguards.

- Technical encryption is required to protect data.

Encrypted pan prevents use after unauthorized access.

- Data is indecipherable, avoiding direct fraud risk.

Storing card data in plain text leads to severe penalties.

- Unencrypted data causes reputation and compliance harm.





Organizational Responsibility and Security Culture

Employee understanding of rules empowers defensive action.

- Training transforms staff into proactive security defenders.

Compliance should go beyond a checklist approach.

- Regular education and communication build vigilance.

Legacy systems can hide unprotected SAD and CHD.

- Overlooked files and applications pose persistent risks.

Mitigation requires both technical and process reviews.

- Automated scans and education address accidental storage.

Defining the Cardholder Data Environment (CDE)

CDE includes all systems handling CHD or SAD.

- All storing, processing, or transmitting data are in scope.

CDE is not limited to physical or single server spaces.

- Networks, devices, and processes are considered.

Flow of card data defines CDE boundaries.

- Information movement determines what is included.

Systems impacting card data integrity belong in the CDE.

- Security influence extends inclusion in scope.



Examples of CDE Components in Organizations

Point-of-sale and payment processing servers are inside CDE.

- Handling or relaying card data requires inclusion.

Connected back-office systems with access join the CDE.

- Even indirect access brings systems into scope.

Any system impacting data confidentiality/integrity joins CDE.

- Access, connectivity, or control warrants inclusion.

CDE scope expands with direct or indirect influence.

- Both direct and indirect system roles matter.



Addressing CDE Boundaries in Modern Architectures

CDE in cloud environments covers numerous components.

- Virtual machines and routing devices may be in scope.

Administrative consoles can also form part of the CDE.

- Any interface impacting card data security is included.

CDE boundaries evolve with technologies and processes.

- Regular reviews are essential for identification.

Inadequate segmentation leads to exploitable security gaps.

- Attackers target overlooked or poorly controlled systems.





Reflecting on Your Organization's CDE Practices

Review CDE boundaries to ensure accurate identification.

- Last CDE review date should be considered carefully.

Peripheral systems may be wrongly included or omitted.

- Inclusion/exclusion errors can affect protection.

Data flows to third parties need close assessment.

- Vendors and service partners can extend CDE.

Boundary assessment is vital for ongoing data protection.

- These reviews protect data and reputation.

Impact of CDE Management on Security Outcomes

Well-defined CDE focuses resources and reduces audit complexity.

- Clear scope reduces time spent and effort during audits.

CDE clarity streamlines incident response processes.

- Defined boundaries enable quicker investigations.

Ambiguity in CDE increases risk of breaches or sanctions.

- Poor control can result in costly, long-term consequences.

CDE management directly affects customer trust and reputation.

- Security failures hurt organizational credibility for years.



Summary: Foundations of Payment Card Data Security

Distinction between CHD and SAD guides all storage policies.

- Only limited CHD, never SAD, may be stored after use.

Encryption and technical controls are central to data safety.

- Security is both technical and behavioral.

CDE boundaries defined by data flow and system influence.

- Document and review CDE regularly for accuracy.

Mastery of data rules empowers secure, trusted operations.

- Vigilance and expertise support organizational protection.

